Federal information in private services

Buying a service, operating a system, and protecting information are different responsibilities. The wording tells us which duties travel with the information.

Research checked 24 October 2026; legal editions vary. Source dates and limits

---

The distinction

An agency can remain responsible for information without operating the private system that handles it. Some requirements follow the information; others attach to a covered system, a particular service, or an agreement. The distinction is real. It is not a blanket exemption for commercially sold services.

This report separates three arrangements: an agency system; an external service collecting or maintaining information for the agency; and a qualifying nonfederal system receiving information for other work. Their obligations can overlap. “Private company,” “external service,” and “nonfederal system” are not interchangeable legal labels.

The question is what an agency must do when it buys access to a provider-run service without taking over its operation. Quotations below supply the rule; the following paragraphs explain its reach and limits.

FISMA: two objects of protection

Quoted passages appear in full below each heading, with their authority and location. Excerpts retain their wording; text extraction normalizes line breaks, line-end word breaks, and spacing before punctuation. Explanations are separate from the quotations.

FISMA assigns two duties under one protection standard

> **Law · 2014-12-18**
>
> providing information security protections commensurate with the risk and magnitude of the harm resulting from unauthorized access, use, disclosure, disruption, modification, or destruction of—
>
> Federal Information Security Modernization Act · 44 USC 3554(a)(1)(A), shared introductory duty; 128 Stat. 3078 · Read original · Source details

> **Law · 2014-12-18**
>
> information collected or maintained by or on behalf of the agency; and
>
> Federal Information Security Modernization Act · §2, enacting 44 USC 3554(a)(1)(A)(i); 128 Stat. 3078 · Read original · Source details

> **Law · 2014-12-18**
>
> information systems used or operated by an agency or by a contractor of an agency or other organization on behalf of an agency;
>
> Federal Information Security Modernization Act · §2, enacting 44 USC 3554(a)(1)(A)(ii); 128 Stat. 3078 · Read original · Source details

These are separate objects of the agency head's duty, joined by "and." The first is information collected or maintained by or on behalf of the agency. The second is systems used or operated by the specified parties. Neither limb says that the agency must own the equipment.

The information clause does not first require declaring a recipient's entire system federal. Conversely, the system clause does not say only "operated": it also says "used," and expressly includes contractor and other-organization operation. This text alone does not resolve which part of a purchased service constitutes the covered system.

The excerpts are from the 2014 enactment. The collected current Code retains these two clauses. The phrases "created," "processed," and "disposed of" belong to the broader information lifecycle language in A-130, not this sentence of FISMA.

Sources and exact locations

- Federal Information Security Modernization Act — 44 USC 3554(a)(1)(A), shared introductory duty; 128 Stat. 3078. Read source
- Federal Information Security Modernization Act — §2, enacting 44 USC 3554(a)(1)(A)(i); 128 Stat. 3078. Read source
- Federal Information Security Modernization Act — §2, enacting 44 USC 3554(a)(1)(A)(ii); 128 Stat. 3078. Read source
- 44 USC 3554 — Federal agency responsibilities — 44 USC 3554(a)(1)(A)(i)–(ii); collected Code through September 30, 2026. Read source

- A-130: Managing Information as a Strategic Resource — §10(22)–(23). Read source

Risk management is a duty, not the only duty

> **Law · 2014-12-18**
>
> complying with the requirements of this subchapter and related policies, procedures, standards, and guidelines, including—
>
> Federal Information Security Modernization Act · 44 USC 3554(a)(1)(B); 128 Stat. 3078 · Read original · Source details

> **Law · 2014-12-18**
>
> periodically testing and evaluating information security controls and techniques to ensure that they are effectively implemented;
>
> Federal Information Security Modernization Act · 44 USC 3554(a)(2)(D); 128 Stat. 3078 · Read original · Source details

> **Law · 2014-12-18**
>
> Each agency shall develop, document, and implement an agency-wide information security program to provide information security for the information and information systems that support the operations and assets of the agency, including those provided or managed by another agency, contractor, or other source, that includes—
>
> Federal Information Security Modernization Act · 44 USC 3554(b); 128 Stat. 3079 · Read original · Source details

Section 3554(a)(2) assigns officials risk assessment, selection of appropriate protection, risk reduction, and testing. Section 3554(b) requires an agency-wide program that includes outside support. The agency cannot satisfy all of this merely by acknowledging that a private service is risky.

These are obligations imposed on the agency. A provider's particular obligations must be traced to an applicable law, regulation, contract, or other agreement. An agency's accountability does not itself confer ownership of the provider or unlimited authority over its business.

Sources and exact locations

- Federal Information Security Modernization Act — 44 USC 3554(a)(1)(B); 128 Stat. 3078. Read source
- Federal Information Security Modernization Act — 44 USC 3554(a)(2)(D); 128 Stat. 3078. Read source
- Federal Information Security Modernization Act — 44 USC 3554(b); 128 Stat. 3079. Read source

- 44 USC 3554 — Federal agency responsibilities — 44 USC 3554(a)(2)(A)–(D), (b)(1)–(8). Read source

---

Service purchase, system operation, and agency responsibility

Buying access is different from commissioning operation

> **NIST guidance · 2018-12-20**
>
> The system owner is an organizational official responsible for the procurement, development, integration, modification, operation, maintenance, and disposal of a system.
>
> SP 800-37 Rev. 2: Security and Privacy RMF · Appendix D, System Owner, p. 123 / PDF p. 142 · Read original · Source details

> **NIST guidance · 2018-12-20**
>
> The authorizing official is a senior official or executive with the authority to formally assume responsibility and accountability for operating a system; providing common controls inherited by organizational systems; or using a system, service, or application from an external provider.
>
> SP 800-37 Rev. 2: Security and Privacy RMF · Appendix D, Authorizing Official, p. 114 / PDF p. 133 · Read original · Source details

A supplier may independently design, own, run, and sell a standard service. The agency buys access and controls its own users and content. A different contract may require a company to build and operate a specified agency application. Those arrangements distribute operational responsibility differently.

NIST's system owner is a management role, not a statement about legal title to equipment. Its authorizing official may accept responsibility for operation OR for use of an external service. An agency authorization to use therefore need not mean that the agency operates the provider's platform.

The presence of an authorizing official does not prove government operation. The absence of a government operator does not prove that a system falls outside FISMA. The statutory classification and the authorization arrangement must each be supported, rather than inferred from the other.

Sources and exact locations

- SP 800-37 Rev. 2: Security and Privacy RMF — Appendix D, System Owner, p. 123 / PDF p. 142. Read source
- SP 800-37 Rev. 2: Security and Privacy RMF — Appendix D, Authorizing Official, p. 114 / PDF p. 133. Read source

- Federal Information Security Modernization Act — §2, 44 USC 3554(a)(1)(A)(ii). Read source
- Modernizing the Federal Risk and Authorization Management Program (FedRAMP) — §IV, footnote 7. Read source

A federal decision maker does not become the platform operator

> **OMB circular · 2016-07-28**
>
> Designate senior Federal officials to formally authorize an information system to operate and authorize agency-designated common controls for use;
>
> A-130: Managing Information as a Strategic Resource · Appendix I §4(d)(1), printed p. 7 / PDF p. 44 · Read original · Source details

> **Mandatory standard · 2006-03-09**
>
> Federal agencies must meet the minimum security requirements as defined herein through the use of the security controls in accordance with NIST Special Publication 800-53, Recommended Security Controls for Federal Information Systems, as amended.
>
> FIPS 200: Minimum Security Requirements · FIPS 200, announcement §8, printed p. v / PDF p. 5 · Read original · Source details

A-130 requires a senior Federal official to authorize operation. FIPS 200 imposes minimum-security requirements on agencies through control selection. These are concrete governance and safeguard requirements; a provider's commercial status is not a substitute for analyzing their applicability.

The role of the federal official is to make the agency's authorization decision. NIST's external-service model separately recognizes provider operation and agency authorization to use. The cited provisions do not establish that a system must have a pre-existing government-appointed system owner before it can meet the statutory system clause. Failure to assign a required role is not itself an exemption.

For a purchased service, record the agency official who accepts the use risk, the provider accountable for service operation, the agency information owner, and the responsibilities the agreement actually grants. Do not describe an agency use authorization as operational control over a private company.

Sources and exact locations

- A-130: Managing Information as a Strategic Resource — Appendix I §4(d)(1), printed p. 7 / PDF p. 44. Read source
- FIPS 200: Minimum Security Requirements — FIPS 200, announcement §8, printed p. v / PDF p. 5. Read source
- A-130: Managing Information as a Strategic Resource — Appendix I §4(d)(1)–(8). Read source

- SP 800-37 Rev. 2: Security and Privacy RMF — Appendix D, p. 114; Appendix G, pp. 159–160. Read source
- FIPS 200: Minimum Security Requirements — Announcement §§6, 8; standard §4. Read source

Information stewardship can remain with the agency

> **NIST guidance · 2018-12-20**
>
> In information-sharing environments, the information owner/steward is responsible for establishing the rules for appropriate use and protection of the information and retains that responsibility even when the information is shared with or provided to other organizations. The owner/steward of the information processed, stored, or transmitted by a system may or may not be the same individual as the system owner.
>
> SP 800-37 Rev. 2: Security and Privacy RMF · Appendix D, Information Owner or Steward, p. 119 / PDF p. 138 · Read original · Source details

This is the clearest practical distinction: the agency can set the permitted purpose, recipients, retention, and protection needs for its information while a private company runs the service. Its information owner and the service's system owner need not be the same person.

The agency can directly control accounts, sharing, exports, endpoint protection, and some tenant settings. For provider-managed functions, it may need agreed commitments, assurance evidence, technical safeguards, or limits on what information may enter the service. Those mechanisms allocate responsibility; they do not transfer operation of the whole platform.

Sources and exact locations

- SP 800-37 Rev. 2: Security and Privacy RMF — Appendix D, Information Owner or Steward, p. 119 / PDF p. 138. Read source
- A-130: Managing Information as a Strategic Resource — Appendix I §4(j)(1)–(2). Read source
- SP 800-53 Rev. 5: Security and Privacy Controls — SA-9; AC-20; CA-3. Read source

The difficult boundary is the work being supplied

> **NIST guidance · 2018-12-20**
>
> For information systems, direct management control involves budgetary, programmatic, or operational authority and associated responsibility and accountability. Direct management control does not necessarily imply that there is no intervening management.
>
> SP 800-37 Rev. 2: Security and Privacy RMF · §2.5, footnote 42, p. 17 / PDF p. 36 · Read original · Source details

> **NIST guidance · 2018-12-20**

> There are instances where system elements, subsystems, or perhaps the entire system may be outside of the direct control of the organization that authorizes its operation.
>
> SP 800-37 Rev. 2: Security and Privacy RMF · Appendix G, p. 159 / PDF p. 178 · Read original · Source details

> **Regulation · 2025**
>
> An information system operated on behalf of an agency provides information processing services to the agency that the Government might otherwise perform itself but has decided to outsource. This includes systems operated exclusively for Government use and systems operated for multiple users (multiple Federal agencies or Government and private sector users).
>
> 32 CFR Part 2002: Controlled Unclassified Information (2025 edition) · 32 CFR 2002.14(h)(1), 2025 annual edition · Read original · Source details

Direct agency control is relevant, but NIST does not make it an absolute condition of authorization. Its management concept includes budgetary and programmatic authority, and it recognizes external systems outside direct control.

The CUI rule goes further within its own scope: outsourced information-processing services can be systems operated on behalf of an agency, including systems with private customers. Selling a shared service and performing work on behalf of an agency are therefore not mutually exclusive under that rule.

This does not settle the government-wide definition for every use of ordinary information. DHS's 2023 response expressly declined to adopt the CUI definition as the general FISMA definition. But it prevents treating "commercial service" as an established categorical exclusion. The report distinguishes this unresolved classification issue from the agency's independently stated information duties.

Sources and exact locations

- SP 800-37 Rev. 2: Security and Privacy RMF — §2.5, footnote 42, p. 17 / PDF p. 36. Read source
- SP 800-37 Rev. 2: Security and Privacy RMF — Appendix G, p. 159 / PDF p. 178. Read source
- 32 CFR Part 2002: Controlled Unclassified Information (2025 edition) — 32 CFR 2002.14(h)(1), 2025 annual edition. Read source
- DHS safeguarding final rule and comment responses — §II.B.7, 88 FR 40571. Read source
- A-130: Managing Information as a Strategic Resource — §10(23); Appendix I §5(r). Read source

What agencies must do for externally handled information

A-130 Appendix I §4(j) addresses non-Federal entities. Its first requirement concerns agreements involving federal information. Its second has two alternative triggers and six specific oversight duties. The quotations preserve that distinction.

1. Put the required protections into the arrangement

> **OMB circular · 2016-07-28**
>
> Ensure that terms and conditions in contracts and other agreements involving the creation, collection, use, processing, storage, maintenance, dissemination, disclosure, and disposal of Federal information, incorporate security and privacy requirements and are sufficient to enable agencies to meet Federal and agency-specific requirements pertaining to the protection of Federal information;
>
> A-130: Managing Information as a Strategic Resource · Appendix I §4(j)(1), printed p. 14 / PDF p. 51 · Read original · Source details

Actor: the agency. Trigger: contracts or other agreements involving the listed activities with federal information. This obligation reaches information handling; its text is not limited to a contract to operate an agency system.

The agency must identify its security and privacy requirements and obtain terms sufficient to meet them. A normal subscription can leave the vendor in operational control, but the agency still has to determine whether the arrangement permits lawful use. This clause does not grant an agency unlimited power to rewrite a supplier's business practices.

Sources and exact locations

- A-130: Managing Information as a Strategic Resource — Appendix I §4(j)(1), printed p. 14 / PDF p. 51. Read source

2. Apply the separate information-handling trigger

> **OMB circular · 2016-07-28**
>
> Provide oversight of information systems used or operated by contractors or other entities on behalf of the Federal Government or that collect or maintain Federal information on behalf of the Federal Government, to include:
>
> A-130: Managing Information as a Strategic Resource · Appendix I §4(j)(2), printed p. 14 / PDF p. 51 · Read original · Source details

The word “or” matters. OMB covers systems used or operated on behalf of government OR systems that collect or maintain federal information on its behalf. Calling the provider’s platform nonfederal does not, by itself, answer whether this second trigger applies.

The heading is “Non-Federal Entities.” That is a description of the counterparties, not a declaration that all of their systems are nonfederal. The following requirements attach to the systems described in this sentence. They should not be silently extended to unrelated corporate systems or every private recipient of public information.

Sources and exact locations

- A-130: Managing Information as a Strategic Resource — Appendix I §4(j)(2), printed p. 14 / PDF p. 51. Read source

3. Establish access oversight and verify protections

> **OMB circular · 2016-07-28**
>
> Documenting and implementing policies and procedures for information security and privacy oversight, to include ensuring appropriate vetting and access control processes for contractors and others with access to information systems containing Federal information;
>
> A-130: Managing Information as a Strategic Resource · Appendix I §4(j)(2)(a), printed p. 14 / PDF p. 51 · Read original · Source details

> **OMB circular · 2016-07-28**
>
> Ensuring that security and privacy controls of such information systems and services are effectively implemented and comply with NIST standards and guidelines and agency requirements;
>
> A-130: Managing Information as a Strategic Resource · Appendix I §4(j)(2)(b), printed p. 14 / PDF p. 51 · Read original · Source details

Actor: the agency, for systems meeting §4(j)(2). The duties include access and vetting oversight and ensuring that controls are effective and comply with the stated requirements. Practical evidence can come from the provider, assessments, and the agreed service arrangements; the agency need not operate every control itself.

This is stronger than a risk assessment alone. It also does not mean every private system receives an identical control set: the applicable standard, information, service, and agreement must be identified.

Sources and exact locations

- A-130: Managing Information as a Strategic Resource — Appendix I §4(j)(2)(a), printed p. 14 / PDF p. 51. Read source

- A-130: Managing Information as a Strategic Resource — Appendix I §4(j)(2)(b), printed p. 14 / PDF p. 51. Read source
- SP 800-37 Rev. 2: Security and Privacy RMF — Appendix G, pp. 159–160. Read source
- SP 800-53 Rev. 5: Security and Privacy Controls — SA-9. Read source

4. Inventory covered systems and document their connections

> **OMB circular · 2016-07-28**
>
> Ensuring that these information systems are included in the agency's inventory of information systems;
>
> A-130: Managing Information as a Strategic Resource · Appendix I §4(j)(2)(c), printed p. 14 / PDF p. 51 · Read original · Source details

> **OMB circular · 2016-07-28**
>
> Ensuring that the interface characteristics, security requirements, and the nature of the information communicated is documented for each interface between these systems and agency-owned or operated information systems;
>
> A-130: Managing Information as a Strategic Resource · Appendix I §4(j)(2)(d), printed p. 14 / PDF p. 51 · Read original · Source details

> **OMB circular · 2016-07-28**
>
> Requiring agreements (e.g., memoranda of understanding, interconnection security agreements, contracts) for interfaces between these information systems and agency-owned or operated information systems;
>
> A-130: Managing Information as a Strategic Resource · Appendix I §4(j)(2)(f), printed p. 14 / PDF p. 51 · Read original · Source details

Actor: the agency, when §4(j)(2) applies. The circular expressly requires inventory inclusion and documentation of interfaces, security requirements, and communicated information. The interface-agreement requirement concerns connections with agency-owned or operated systems.

Inventory is not ownership. An agency can record a service it uses without taking control of its provider. These clauses nevertheless contradict a universal claim that externally handled information creates no system-level oversight duties.

Sources and exact locations

- A-130: Managing Information as a Strategic Resource — Appendix I §4(j)(2)(c), printed p. 14 / PDF p. 51. Read source
- A-130: Managing Information as a Strategic Resource — Appendix I §4(j)(2)(d), printed p. 14 / PDF p. 51. Read source

- A-130: Managing Information as a Strategic Resource — Appendix I §4(j)(2)(f), printed p. 14 / PDF p. 51. Read source

5. Arrange incident response

> **OMB circular · 2016-07-28**
>
> Ensuring that procedures are in place for incident response for these information systems including timelines for notification of affected individuals and reporting to OMB, DHS, and other entities as required in OMB guidance;
>
> A-130: Managing Information as a Strategic Resource · Appendix I §4(j)(2)(e), printed p. 14 / PDF p. 51 · Read original · Source details

Actor: the agency, for the covered systems. Establish response procedures and applicable reporting and notification timelines. The agency needs a workable route for learning about incidents and obtaining the information it must report; provider cooperation should be addressed in the arrangement.

This quote does not prescribe one universal vendor reporting deadline. The relevant OMB guidance, information, incident, and contract determine the specific obligations.

Sources and exact locations

- A-130: Managing Information as a Strategic Resource — Appendix I §4(j)(2)(e), printed p. 14 / PDF p. 51. Read source
- 44 USC 3554 — Federal agency responsibilities — 44 USC 3554(b)(7). Read source

6. Protect information even on incidental equipment

> **OMB circular · 2016-07-28**
>
> Therefore, when Federal information is used within incidentally acquired equipment, the agency continues to be responsible and accountable for ensuring that FISMA requirements are met for such information.
>
> A-130: Managing Information as a Strategic Resource · Appendix I §5(r), printed p. 26 / PDF p. 63 · Read original · Source details

This sentence expressly locates continuing FISMA accountability in the information. It follows a discussion of contractor equipment acquired incidentally to a contract, which the Clinger–Cohen IT definition excluded.

It supports the distinction you are investigating: excluding equipment from one statutory definition does not remove the agency's information-protection duty. It does not say that the whole equipment environment becomes an agency system or that every safeguard for an agency system applies unchanged.

Sources and exact locations

- A-130: Managing Information as a Strategic Resource — Appendix I §5(r), printed p. 26 / PDF p. 63. Read source
- A-130: Managing Information as a Strategic Resource — Appendix I §5(r), pp. 25–26. Read source
- Clinger–Cohen Act in P.L. 104-106 — Division E §5002(3), now 40 USC 11101(6). Read source

Where the requirements differ —and where they overlap

The nonfederal column assumes the system qualifies as nonfederal under the governing authority. Whether a particular cloud service meets that assumption is the separate question above. Information-handling duties may still overlap; each row states its trigger. Read the conditions before applying a result.

Agency responsibilities, by subject

Subject	Federal information system	Federal information in a nonfederal system	Scope and conditions
What triggers protection	Covered federal systems and their information fall within the agency security program.	The agency's information duty can survive outside an agency-operated system.	Generally applicable agency duty; §3554(a)(1)(A) does not make every recipient an agency. Sources and exact locations • 44 USC 3554 — Federal agency responsibilities — §3554(a)(1)(A), (b). Read source

Subject	Federal information system	Federal information in a nonfederal system	Scope and conditions
Control of operations	The system owner and operator have defined lifecycle and implementation responsibilities.	The provider may retain platform operation; the agency governs its use and the information it provides.	Role allocation differs. Ownership, service purchase, and system classification are separate questions. Sources and exact locations • SP 800-37 Rev. 2: Security and Privacy RMF — Appendix D, pp. 114, 119, 123; Appendix G. Read source
Categorization and safeguards	FIPS 199/200 and applicable agency requirements guide categorization, minimum safeguards, and control selection.	Select protections for the information and actual arrangement. CUI, covered contract information, and privacy have additional triggers.	No universal lighter baseline for all nonfederal handling is established here. SP 800-171 is not the general ordinary-information baseline. Sources and exact locations • FIPS 199: Security Categorization — §§2–3. Read source • FIPS 200: Minimum Security Requirements — §§2–3. Read source • SP 800-171 Rev. 3: Protecting CUI — §1.1. Read source

Subject	Federal information system	Federal information in a nonfederal system	Scope and conditions
Authorization	Agency-system authorization addresses the specified system, controls, and risk.	An agency may authorize use of an external service. That decision does not give it operational control of the provider.	Conditional: a FedRAMP-covered service has its own authorization obligations; a program exclusion is not an exemption from all duties. Sources and exact locations • SP 800-37 Rev. 2: Security and Privacy RMF — Appendix D, p. 114; Appendix G, p. 160. Read source • Modernizing the Federal Risk and Authorization Management Program (FedRAMP) — §§III–IV, footnote 7. Read source
Assessment and monitoring	The agency assesses controls and monitors the system under its applicable authorization process.	The agency must obtain sufficient assurance for its information and use. §4(j)(2)(b) expressly requires effective controls when its trigger is met.	External evidence and inherited controls can change who performs the work. They do not eliminate the agency's accountability. Sources and exact locations • 44 USC 3554 — Federal agency responsibilities — §3554(a)(2)(D), (b)(5). Read source • A-130: Managing Information as a Strategic Resource — Appendix I §4(j)(2)(b). Read source • SP 800-37 Rev. 2: Security and Privacy RMF — Appendix G. Read source

Subject	Federal information system	Federal information in a nonfederal system	Scope and conditions
Inventory and interfaces	Agency inventory and system connections have specified management requirements.	§4(j)(2)(c)–(f) also covers systems collecting or maintaining information on behalf, including inventory and interface agreements.	Conditional on the wording of that provision. Not a finding that every private recipient's system belongs in the agency inventory. Sources and exact locations • A-130: Managing Information as a Strategic Resource — Appendix I §4(j)(2)(c)–(f). Read source
Incident response	Agency detection, response, and reporting obligations apply to covered incidents.	Protecting information externally requires response arrangements; covered external systems have explicit procedures under §4(j)(2)(e).	The agency's reporting duty and a supplier's contractual notification duty are distinct. Sources and exact locations • 44 USC 3554 — Federal agency responsibilities — §3554(b)(7). Read source • A-130: Managing Information as a Strategic Resource — Appendix I §4(j)(2)(e). Read source

Subject	Federal information system	Federal information in a nonfederal system	Scope and conditions
CUI confidentiality	Under the CUI rule, on-behalf systems are treated as agency systems and can receive additional agency requirements.	The rule prohibits treating qualifying nonfederal systems as agency systems and directs SP 800-171 for CUI confidentiality, with exceptions.	A real difference, expressly scoped to CUI. Read the outsourcing definition, exceptions, and incorporated edition together. Sources and exact locations • 32 CFR Part 2002: Controlled Unclassified Information (2025 edition) — 32 CFR 2002.14(h)(1)–(2); 2002.2. Read source • SP 800-171 Rev. 3: Protecting CUI — §1.1 and footnote 8. Read source
Retention, disclosure, and exit	The agency follows applicable records, disclosure, and disposal requirements.	Those information duties can remain when a private service holds copies. Arrange access, preservation, return, and lawful disposal.	Conditional on the particular information and law; not every company record becomes an agency record. Sources and exact locations • 44 USC 3301 — Federal records — 44 USC 3301. Read source • 5 USC 552 — FOIA — 5 USC 552(f)(2)(B). Read source • NARA Bulletin 2010-05: Guidance on Managing Records in Cloud Computing Environments — Questions 6–8. Read source

Additional triggers, express limits, and overlapping guidance

Ordinary federal information is the starting point. The provisions below add conditions for specific information or services; they do not all apply to every document.

CUI: an express limit on treating private systems as agency systems

> **Regulation · 2025**
>
> Agencies may not treat non-Federal information systems as though they are agency systems, so agencies cannot require that non-executive branch entities protect these systems in the same manner that the agencies might protect their own information systems.
>
> 32 CFR Part 2002: Controlled Unclassified Information (2025 edition) · 32 CFR 2002.14(h)(2), 2025 annual edition · Read original · Source details

> **Regulation · 2025**
>
> When a non-executive branch entity receives Federal information only incidental to providing a service or product to the Government other than processing services, its information systems are not considered Federal information systems.
>
> 32 CFR Part 2002: Controlled Unclassified Information (2025 edition) · 32 CFR 2002.14(h)(2), 2025 annual edition · Read original · Source details

> **Regulation · 2025**
>
> Agencies must use NIST SP 800-171 when establishing security requirements to protect CUI's confidentiality on non-Federal information systems (unless the authorizing law, regulation, or Government-wide policy listed in the CUI Registry for the CUI category or subcategory of the information involved prescribes specific safeguarding requirements for protecting the information's confidentiality, or unless an agreement establishes requirements to protect CUI Basic at higher than moderate confidentiality).
>
> 32 CFR Part 2002: Controlled Unclassified Information (2025 edition) · 32 CFR 2002.14(h)(2), 2025 annual edition · Read original · Source details

These are binding regulatory words within the CUI program. They expressly distinguish the protection of information on a qualifying nonfederal system from treating that system as the agency's own.

The same paragraph directs agencies to SP 800-171 for CUI confidentiality, unless the listed authority prescribes specific safeguards or an agreement establishes protection above moderate confidentiality for CUI Basic. The preceding paragraph covers outsourced processing, including mixed public/private customer systems. Both sides of the rule must be retained.

An entity receiving specifications to manufacture a product is different from an entity hired to process or host the agency's records under this rule. "Incidental" describes the purpose of the receipt, not simply that the service is commercially available.

Sources and exact locations

- 32 CFR Part 2002: Controlled Unclassified Information (2025 edition) — 32 CFR 2002.14(h)(2), 2025 annual edition. Read source
- 32 CFR Part 2002: Controlled Unclassified Information (2025 edition) — 32 CFR 2002.14(h)(1)–(2); 2002.4(hh). Read source

SP 800-171 is a bounded branch, not a substitute for every external service

> **NIST guidance · 2024-05-14**
>
> The requirements do not apply to nonfederal organizations that are collecting or maintaining information on behalf of a federal agency or using or operating a system on behalf of an agency.
>
> SP 800-171 Rev. 3: Protecting CUI · §1.1, p. 2 / PDF p. 12; read with footnote 8 · Read original · Source details

> **NIST guidance · 2024-05-14**
>
> The security requirements in this publication are only applicable to components of nonfederal systems that process, store, or transmit CUI or that provide protection for such components.
>
> SP 800-171 Rev. 3: Protecting CUI · §1.1, p. 2 / PDF p. 12 · Read original · Source details

> **NIST guidance · 2024-05-14**
>
> The requirements are intended for use by federal agencies in contractual vehicles or other agreements that are established between those agencies and nonfederal organizations.
>
> SP 800-171 Rev. 3: Protecting CUI · §1.1, p. 2 / PDF p. 12 · Read original · Source details

Revision 3 states that its requirements do not apply to organizations collecting or maintaining information on behalf of an agency, as well as those using or operating a system on its behalf. Footnote 8 directs those activities to FISMA. The information limb therefore cannot simply be assigned wholesale to SP 800-171.

For the branch where SP 800-171 does apply, component scope and a separate security domain can limit implementation to CUI-handling and protecting components. The document focuses on CUI confidentiality; it is not a general exemption from other applicable laws or agreements.

The collected 2025 CFR incorporates the June 2015 publication with January 2016 updates. Revision 3 is current NIST guidance in this review, not proof that every contract or regulation automatically adopted it. Identify the governing edition for the actual arrangement.

Sources and exact locations

- SP 800-171 Rev. 3: Protecting CUI — §1.1, p. 2 / PDF p. 12; read with footnote 8. Read source
- SP 800-171 Rev. 3: Protecting CUI — §1.1, p. 2 / PDF p. 12. Read source
- SP 800-171 Rev. 3: Protecting CUI — §1.1, footnote 8; §2. Read source
- 32 CFR Part 2002: Controlled Unclassified Information (2025 edition) — 32 CFR 2002.2(b)(5), 2002.14(h)(2). Read source

Cloud-program requirements can follow information handling

> **OMB circular · 2016-07-28**
>
> This includes services that are either fully or partially provided, including agency-hosted, outsourced, and cloud-based solutions.
>
> A-130: Managing Information as a Strategic Resource · Appendix I §5(r), printed p. 25 / PDF p. 62 · Read original · Source details

> **OMB memorandum · 2024-07-25**
>
> The scope of FedRAMP is cloud computing products and services (such as IaaS, Platform-as-a-Service (PaaS), and SaaS) that create, collect, process, store, or maintain Federal information on behalf of a Federal agency, and that are not otherwise specified as out of scope below.
>
> Modernizing the Federal Risk and Authorization Management Program (FedRAMP) · §III, p. 5; exclusions follow this sentence · Read original · Source details

> **OMB memorandum · 2024-07-25**
>
> Agencies leverage the FedRAMP authorization package to issue their own “authorization to operate” (ATO) or “authorization to use” (ATU). FedRAMP does not replace other legal, Executive Order, regulatory, or OMB-issued compliance requirements for areas such as information management, records management, privacy, and cybersecurity.
>
> Modernizing the Federal Risk and Authorization Management Program (FedRAMP) · §IV, footnote 7, p. 6 · Read original · Source details

M-24-15 uses information-handling verbs to set FedRAMP’s scope, subject to express exclusions. It does not limit that scope to services the government itself operates. Its footnote distinguishes agency authorization to use from authorization to operate.

This is why service purchase versus delegated operation matters without resolving everything. An external service can remain provider-run and still require a specified assessment or authorization for agency use. The relevant offering is not automatically the provider’s entire company.

Figma-style design work must be examined against the service, information, and exclusions. An agency application on IaaS requires separate analysis of the workload and the hosting service. The

retrieved program guidance informs these decisions; it does not amend FISMA.

Sources and exact locations

- A-130: Managing Information as a Strategic Resource — Appendix I §5(r), printed p. 25 / PDF p. 62. Read source
- Modernizing the Federal Risk and Authorization Management Program (FedRAMP) — §III, p. 5; exclusions follow this sentence. Read source
- Modernizing the Federal Risk and Authorization Management Program (FedRAMP) — §IV, footnote 7, p. 6. Read source
- FedRAMP scope guidance, retrieved October 24, 2026 — Agency Use Case Indicators; Social Media & Communications; Single Agency Systems. Read source
- Modernizing the Federal Risk and Authorization Management Program (FedRAMP) — §III exclusions. Read source

NIST also contains broad external-provider language

> **NIST guidance · 2018-12-20**
>
> FISMA and OMB policy require external providers that process, store, or transmit federal information or operate information systems on behalf of the federal government to meet the same security and privacy requirements as federal agencies.
>
> SP 800-37 Rev. 2: Security and Privacy RMF · Appendix G, p. 159 / PDF p. 178 · Read original · Source details

> **NIST guidance · 2018-12-20**
>
> Alternatively, organizations may allow externally provided systems or services to be used only in those instances where the exchange of information risk determined by the organization is acceptable.
>
> SP 800-37 Rev. 2: Security and Privacy RMF · Appendix G, p. 160 / PDF p. 179 · Read original · Source details

The first passage is NIST's description of FISMA and OMB policy, not statutory text. It is broader than a claim that external information handling requires only a risk acknowledgment. The second describes an alternative based on information-exchange risk in the same discussion.

Read these passages with A-130's actual triggers and the CUI rule's express limits. "Same requirements" does not mean that unrelated corporate systems become federal systems, nor does a risk-based alternative waive a binding obligation. The report does not resolve these different scopes by silently choosing one quotation.

Sources and exact locations

- SP 800-37 Rev. 2: Security and Privacy RMF — Appendix G, p. 159 / PDF p. 178. Read source
- SP 800-37 Rev. 2: Security and Privacy RMF — Appendix G, p. 160 / PDF p. 179. Read source
- SP 800-37 Rev. 2: Security and Privacy RMF — Appendix G, pp. 159–160. Read source
- A-130: Managing Information as a Strategic Resource — Appendix I §4(j), §5(r). Read source
- 32 CFR Part 2002: Controlled Unclassified Information (2025 edition) — 32 CFR 2002.14(h). Read source

Additional duties need their own trigger

> **Regulation · 2021-11**
>
> Federal contract information means information, not intended for public release, that is provided by or generated for the Government under a contract to develop or deliver a product or service to the Government, but not including information provided by the Government to the public (such as on public websites) or simple transactional information, such as necessary to process payments.
>
> FAR 52.204-21, November 2021 clause; FAC 2026-01 · FAR 52.204-21(a), definition; November 2021 clause, retrieved FAC 2026-01 · Read original · Source details

> **Regulation · 2021-11**
>
> The Contractor shall apply the following basic safeguarding requirements and procedures to protect covered contractor information systems.
>
> FAR 52.204-21, November 2021 clause; FAC 2026-01 · FAR 52.204-21(b)(1) · Read original · Source details

> **Law · 1974-12-31**
>
> When an agency provides by a contract for the operation by or on behalf of the agency of a system of records to accomplish an agency function, the agency shall, consistent with its authority, cause the requirements of this section to be applied to such system.
>
> Privacy Act, P.L. 93-579 · Privacy Act of 1974 §3, adding 5 USC 552a(m); 88 Stat. 1904 / PDF p. 9 · Read original · Source details

Federal contract information: FAR 52.204-21 applies through the covered contract clause. Its definition excludes publicly released information and simple payment transactions. A company's covered contractor system receives specified safeguards, not an automatic conversion of its entire business into an agency system.

Personal information: Privacy Act subsection (m) has a specific trigger—contracting for operation of a system of records to accomplish an agency function. Not every document with a person's name is such a system; subsection (a)(5) concerns records retrieved by an individual's name or other identifying particular. Other privacy obligations may apply even where (m) does not.

These provisions illustrate why an obligation matrix must name its authority and trigger. "Federal information" alone does not make every rule in every information regime applicable.

Sources and exact locations

- FAR 52.204-21, November 2021 clause; FAC 2026-01 — FAR 52.204-21(a), definition; November 2021 clause, retrieved FAC 2026-01. Read source
- FAR 52.204-21, November 2021 clause; FAC 2026-01 — FAR 52.204-21(b)(1). Read source
- Privacy Act, P.L. 93-579 — Privacy Act of 1974 §3, adding 5 USC 552a(m); 88 Stat. 1904 / PDF p. 9. Read source
- 5 USC 552a — Records maintained on individuals — 5 USC 552a(a)(5), (b), (e), (m). Read source
- FAR 52.204-21, November 2021 clause; FAC 2026-01 — FAR 52.204-21(a)–(c). Read source

Records duties follow qualifying records into a service

> **Guidance · 2010-09-08**
>
> In the SaaS service model, the agency may maintain records in contractor-provided clouds, and any negotiated contract language will need to address specific records management responsibilities.
>
> NARA Bulletin 2010-05: Guidance on Managing Records in Cloud Computing Environments · NARA Bulletin 2010-05, question 6 (September 8, 2010) · Read original · Source details

> **Law · 2024 Code edition**
>
> any information described under subparagraph (A) that is maintained for an agency by an entity under Government contract, for the purposes of records management.
>
> 5 USC 552 — FOIA · 5 USC 552(f)(2)(B), 2024 Code edition · Read original · Source details

NARA recognizes that agency control varies by service model and directs attention to negotiated responsibilities. Determine which content is a federal record, whether it remains accessible, how preservation and legal holds work, and how it will be returned or disposed of.

The FOIA quotation is part of its definition of a record. It reaches qualifying information held under a government records-management contract; it does not turn every private company record into an agency record. Records status, access rights, and disclosure restrictions require their own analysis.

Sources and exact locations

- NARA Bulletin 2010-05: Guidance on Managing Records in Cloud Computing Environments — NARA Bulletin 2010-05, question 6 (September 8, 2010). Read source
- 5 USC 552 — FOIA — 5 USC 552(f)(2)(B), 2024 Code edition. Read source
- 44 USC 3301 — Federal records — 44 USC 3301. Read source
- NARA Bulletin 2010-05: Guidance on Managing Records in Cloud Computing Environments — Questions 6–8. Read source
- 5 USC 552 — FOIA — 5 USC 552(f)(2)(B). Read source

Follow the information from creation to disposal

The same document can move through several systems and several legal regimes. These questions help keep the duties attached to the right activity.

1 Create and collect

An employee creates a design; a form collects responses.

Determine the agency purpose, the information involved, and authority to collect it. Collection from the public may trigger PRA review; personally identifiable information can trigger privacy analysis. Creating a design does not by itself trigger every one of those rules.

Sources and exact locations

- 44 USC 3506 — Federal agency responsibilities — 44 USC 3506(c). Read source
- 5 USC 552a — Records maintained on individuals — 5 USC 552a(e), (m). Read source
- A-130: Managing Information as a Strategic Resource — §5; Appendix II. Read source

---

2 Process and store

The application renders designs and keeps versions, comments, and copies.

Follow the information into provider storage, backups, support access, and subprocessors. Identify who implements protections. An agency-owned encryption key or tenant setting can reduce exposure without removing every service dependency.

Sources and exact locations

- 44 USC 3554 — Federal agency responsibilities — 44 USC 3554(a)–(b). Read source
- SP 800-53 Rev. 5: Security and Privacy Controls — SA-9; SC-28, Protection of Information at Rest. Read source
- NIST SP 800-18 Revision 2 — §3.2. Read source

3 Transmit and exchange

A browser sends content across networks; an API shares it with another service.

Assess the endpoints, the exchange, and the transmission channel. Specify authorized recipients, authentication, protection in transit, and responsibilities after receipt. Exchanging information does not require placing every intervening network inside one authorization boundary.

Sources and exact locations

- NIST SP 800-47 Revision 1 — §§2–3. Read source
- SP 800-53 Rev. 5: Security and Privacy Controls — CA-3; SC-7; SC-8, Transmission Confidentiality and Integrity. Read source
- SP 800-37 Rev. 2: Security and Privacy RMF — §2.4; Appendix G. Read source

4 Use, share, and publish

Staff collaborate, export a design, or publish a finished page.

Check purpose and disclosure restrictions independently from system authorization. Permission to use a secure service does not authorize every disclosure. Public release also does not make integrity or availability irrelevant.

Sources and exact locations

- 5 USC 552a — Records maintained on individuals — 5 USC 552a(b). Read source
- 32 CFR Part 2002: Controlled Unclassified Information (2025 edition) — 32 CFR 2002.16, 2002.18. Read source
- FIPS 199: Security Categorization — §3. Read source

5 Retain and retrieve

Versions and comments may document agency decisions.

Determine which materials are federal records and how the agency will retrieve, preserve, search, and transfer them. Outsourced storage does not remove records duties. FOIA expressly includes qualifying records maintained for an agency by a records-management contractor; it does not make every company record an agency record.

Sources and exact locations

- 44 USC 3301 — Federal records — 44 USC 3301. Read source
- NARA Bulletin 2010-05: Guidance on Managing Records in Cloud Computing Environments — NARA Bulletin 2010-05, questions 6–8. Read source
- 5 USC 552 — FOIA — 5 USC 552(f)(2)(B). Read source

6 Return and dispose

The agency ends the subscription or replaces the service.

Plan export, legal holds, retention schedules, deletion, backup handling, and incident evidence before exit. Closing an account is not proof that all required records were retained or every provider copy was destroyed.

Sources and exact locations

- NARA Bulletin 2010-05: Guidance on Managing Records in Cloud Computing Environments — Questions 6–8. Read source
- NIST SP 800-18 Revision 2 — §3.2, System Operational Status; SP 800-37 Task M-7. Read source
- 32 CFR Part 2002: Controlled Unclassified Information (2025 edition) — 32 CFR 2002.14(f). Read source

Compare the examples

The first three examples compare buying SaaS access, operating an IaaS workload, and commissioning application operation. Incidental handling and internet transit provide contrasting cases. These are stated assumptions, not vendor compliance findings.

Design work in Figma

Assumptions. Agency staff use a commercial design workspace for website layouts. The provider stores designs and comments. No claim is made about any actual Figma offering, contract, authorization, or security architecture.

Information and service relationships

Agency staff create designs › Provider processes and stores the workspace › Agency exports or publishes the result

The fact that it is commercial SaaS does not settle "on behalf of."

The agency creates the substantive content; the service processes and maintains it. That can be information handling for the agency even though the agency does not operate the provider's platform. In the CUI framework, a service whose job is information processing is different from receiving information merely incidentally to an unrelated service.

Simple website layouts may carry little confidentiality risk. That does not prove the service is out of scope: unreleased plans, research notes, user data, access credentials, or deployment integrations change the facts. A tenant can allocate user-management duties while provider controls remain relevant.

For an agency-approved public or nonsensitive collaboration use, the retrieved FedRAMP guidance supplies examples of exclusions that may be relevant. Applying one requires a use-case analysis; the report does not equate Figma with an expressly excluded product. Even an excluded use can leave security, privacy, records, and appropriate-use duties.

Agency	Purpose, information classification, authorized use, accounts, sharing, records, and the risk decision.
Provider under the applicable agreement	Service operation, platform protections, relevant support access, incident cooperation, retention and return commitments.

Boundary to examine	Workspace plus the service components and external dependencies that process or protect its content; not automatically the whole company.

What could change the answer?

A public workshop board with no sensitive content is different from a private design repository integrated with agency identity and production deployment. Copying CUI or personal data into the workspace requires a fresh analysis.

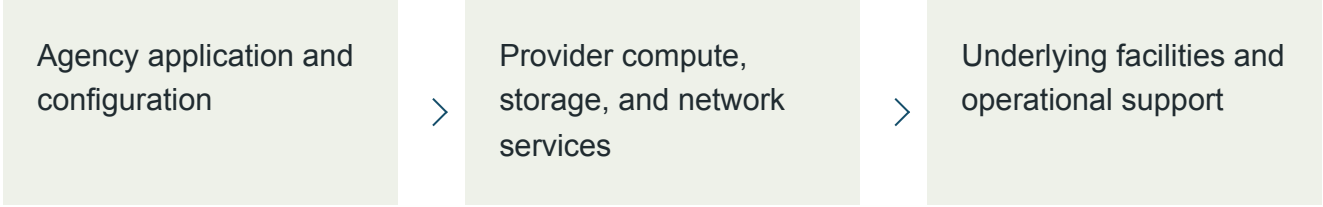
Sources and exact locations

- 44 USC 3554 — Federal agency responsibilities — 44 USC 3554(a)(1)(A). Read source
- 32 CFR Part 2002: Controlled Unclassified Information (2025 edition) — 32 CFR 2002.14(h). Read source
- Modernizing the Federal Risk and Authorization Management Program (FedRAMP) — §III. Read source
- FedRAMP scope guidance, retrieved October 24, 2026 — Social Media & Communications; Agency Use Case Indicators. Read source
- SP 800-37 Rev. 2: Security and Privacy RMF — Appendix G. Read source

An agency application on AWS

Assumptions. The agency manages an application and virtual resources on commercial IaaS. AWS is an illustration of the service model, not a finding about any region, product, contract, or current authorization.

Information and service relationships



The agency workload and the infrastructure can have separate boundaries and connected responsibilities.

The agency can operate its application while the provider operates infrastructure that processes and stores agency information. The presence of an agency-controlled tenant does not mean the infrastructure performs no work on its behalf.

An application-only authorization may inherit protections from its host. The agency must identify which protections are inherited, what evidence supports them, and what it still implements. A host authorization does not authorize every application, configuration, integration, or use of information.

The provider's service boundary can include shared components relevant to confidentiality, integrity, and availability without embracing every corporate function or other customer's workload. The exact boundary follows the offering and its architecture.

Agency	Application code, workload configuration, permissions, data, application safeguards, and risk acceptance.
Infrastructure provider	The defined infrastructure service and its provider-implemented safeguards; details depend on the offering.
Boundary to examine	The application authorization, host-service authorization, inherited controls, and connections between them.

What could change the answer?

Adding a managed database, support access path, third-party backup service, or a different region can change the applicable service scope and evidence.

Sources and exact locations

- SP 800-145: The NIST Definition of Cloud Computing — §2, IaaS definition. Read source
- SP 800-37 Rev. 2: Security and Privacy RMF — Appendix G, pp. 159–161. Read source
- Modernizing the Federal Risk and Authorization Management Program (FedRAMP) — §III. Read source

- NIST SP 800-18 Revision 2 — §3.2. Read source

A contractor builds and runs the agency's application

Assumptions. A contract expressly requires a company to build and operate an agency application on commercial cloud infrastructure. The application serves one agency and is not itself a reusable shared offering.

Information and service relationships

Agency commissions the function > Contractor runs the application > Cloud provider runs the host service

Subcontracting the infrastructure does not end the contractor's work on behalf of the agency.

The operating contract is strong evidence of agency-purpose system operation. The application may be a federal system even though both its operator and its infrastructure provider are private. The agency must arrange responsibilities across both layers.

M-24-15 excludes certain single-agency systems from FedRAMP. That program exclusion can apply to the custom application without excluding the host cloud service. It also does not exempt the custom system from agency security authorization or other applicable duties.

A development-only contract has different facts: delivering code is not the same as operating a production system. The developer's internal business tools need their own analysis of information, access, contractual requirements, and any incidental processing.

Agency	Mission, requirements, oversight, information duties, authorization, and applicable contracting terms.
Application contractor	Agreed development and operational responsibilities, application controls, incident duties, and host integration.

Cloud provider	Host-service protections and evidence; the contractor must account for what the application inherits.

What could change the answer?

Selling the same application as a multi-agency SaaS offering changes the FedRAMP scope question. Removing operation from the contract changes the system-role analysis.

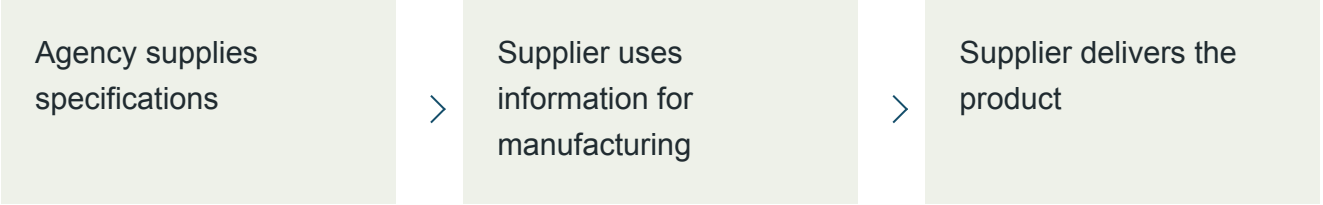
Sources and exact locations

- 44 USC 3554 — Federal agency responsibilities — 44 USC 3554(a)–(b). Read source
- A-130: Managing Information as a Strategic Resource — Appendix I §4(j). Read source
- Modernizing the Federal Risk and Authorization Management Program (FedRAMP) — §III, exclusion 1. Read source
- FedRAMP scope guidance, retrieved October 24, 2026 — Single Agency Systems. Read source
- SP 800-37 Rev. 2: Security and Privacy RMF — Appendix G. Read source

A company uses agency information to deliver another service

Assumptions. A supplier receives government specifications to manufacture a product. Its internal system supports that work; the agency has not outsourced an information-processing service to it.

Information and service relationships



A nonfederal system can still carry enforceable information-protection duties.

The CUI rule explicitly distinguishes information received only incidentally to a service or product other than processing services. Under that rule, the supplier's system is not made federal merely by holding the information.

If the specifications are CUI, the rule directs agencies to SP 800-171 for CUI confidentiality on nonfederal systems, with stated exceptions. The publication allows a defined security domain and covers components processing, storing, transmitting, or protecting CUI. It does not require protecting the entire business to an undifferentiated agency standard.

For covered federal contract information, FAR 52.204-21 can impose safeguards through a contract clause. Public information and simple payment transaction information are excluded from that clause's definition of federal contract information. These are specific limits, not a blanket exemption for commercial businesses.

Agency	Identify the information and applicable requirements; use lawful contract or agreement terms.
Supplier	Meet the applicable contract and information-protection obligations on its covered systems.
Boundary to examine	The components handling or protecting covered information, including dependencies; an isolated domain can reduce scope.

What could change the answer?

A contract to host, index, or process the agency's records changes the purpose: information processing is then the purchased service, not incidental support for manufacturing.

Sources and exact locations

- 32 CFR Part 2002: Controlled Unclassified Information (2025 edition) — 32 CFR 2002.14(h)(2). Read source
- SP 800-171 Rev. 3: Protecting CUI — §1.1. Read source

- FAR 52.204-21, November 2021 clause; FAC 2026-01 — FAR 52.204-21(a)–(c). Read source

Agency information crosses the internet

Assumptions. Agency endpoints exchange information over public networks. No single operator runs “the internet,” and ordinary transit is distinguished from a separately purchased managed network or cloud service.

Information and service relationships

Agency endpoint protects information	External networks carry the transmission	Authorized endpoint receives it

A network dependency does not make the entire internet one federal system.

An information system is a discrete set of resources organized for information activities. An authorization covers a defined system and its responsibilities. Public networks may lie outside that boundary while still being part of the environment and a source of risk.

The agency protects the exchange through appropriate endpoint controls, authentication, encryption, connection rules, and agreements where applicable. SP 800-47 focuses on protection before, during, and after an exchange; it does not require ownership of the channel.

Do not turn this into “telecommunications can never be on behalf of government.” OMB’s outsourcing examples include telecommunications and managed services. A purchased managed network, a carrier contract, a cloud endpoint, and an arbitrary transit network can present different relationships.

Agency	Protect endpoints and exchanges, assess availability and interception risks, and authorize use.
Relevant service providers	Meet obligations for the specific services they supply; examine the actual contracts and legal regimes.

Boundary to examine	Defined endpoints and services, external connections, and risk controls —not the internet as a single owned asset.

What could change the answer?

Hiring a provider to run a private agency network or an application gateway adds a specific operated service to the analysis.

Sources and exact locations

- 44 USC 3502 — Definitions — 44 USC 3502(8). Read source
- SP 800-37 Rev. 2: Security and Privacy RMF — §§2.4–2.5; Appendix G. Read source
- NIST SP 800-47 Revision 1 — §§2–3. Read source
- M-10-15, FY 2010 Reporting Instructions for the Federal Information Security Management Act and Agency Privacy Management — Question 38, printed pp. 14–15. Read source

---

How the distinction developed

This history follows duties and definitions across different authorities. A later document does not automatically repeal an earlier rule or settle its meaning.

OMB expressly distinguished agency and contractor duties

> **OMB circular · 1993-06-25**
>
> Thus the information responsibilities of grantees and contractors are not identical to those of Federal agencies except to the extent that the agencies make them so in the underlying grants or contracts.
>
> A-130: Transmittal 1 · Appendix IV §3, analysis of §6: Government Information (1993) · Read original · Source details

This 1993 explanation is strong evidence for distinguishing an agency's obligations from a counterparty's. It does not say private services cannot handle information on behalf of an agency. The later security, CUI, and cloud provisions must be read on their own terms.

The selected chronology below preserves the relevant legislative and comment history. Comments express their authors' positions; they are not adopted law. The incomplete 2015 comment docket remains a stated research gap.

Sources and exact locations

- A-130: Transmittal 1 — Appendix IV §3, analysis of §6: Government Information (1993). Read source
- A-130: Transmittal 3 — Appendix IV, Government Information. Read source
- A-130 (2000), Appendix IV — §3, Government Information. Read source

1974

Law

Congress addresses outsourced records about people

The Privacy Act required agencies contracting for operation of a system of records to cause its requirements to apply when the operation accomplishes an agency function. Congress supplied a specific contractual bridge. It did not simply make every private recipient of government information a federal agency.

Sources and exact locations

- Privacy Act, P.L. 93-579 — §3, adding 5 USC 552a(m). Read source
- 5 USC 552a — Records maintained on individuals — 5 USC 552a(m). Read source

---

1980–1985

Law and OMB policy

Information management extends beyond the agency's machines

The Paperwork Reduction Act assigned government-wide and agency information-management responsibilities. The first A-130 addressed information handled by or for government. Its analysis also recognized that program managers often depend on contracted technical services they do not directly control. Accountability for the program remained with the agency.

Sources and exact locations

- Paperwork Reduction Act of 1980 — 44 USC 3504–3506 as enacted. Read source
- A-130: initial circular — §6; Appendix IV, analysis of §8b(2)–(3), 50 FR 52749; PDF p. 307. Read source

---

1988

Law

The Computer Security Act covers contractor-operated systems

The Computer Security Act of 1987, enacted January 8, 1988, defined federal computer systems to include specified contractor-operated systems processing information to accomplish a federal function. It assigned standards work and required security planning for systems with sensitive information. Contractor operation was already part of the statutory picture before commercial cloud computing.

Sources and exact locations

- Computer Security Act of 1987, P.L. 100-235 — §3, adding NBS Act §20(d)(2); §§5–7. Read source

---

1993–2000

OMB policy

OMB says the agency's duties do not automatically become the contractor's

The 1993 analysis of "government information" explains that broad information coverage does not extend responsibility for implementing the circular beyond executive agencies. It points to differences in FOIA and copyright treatment and says contractor and grantee duties are not identical to agency duties except as made so in their agreements. The 1996 and 2000 texts retain that explanation.

Sources and exact locations

- A-130: Transmittal 1 — Appendix IV, §3, Government Information. Read source
- A-130: Transmittal 3 — Appendix IV, Government Information. Read source
- A-130 (2000), Appendix IV — §3, Government Information. Read source

---

1996

Law and OMB policy

Incidental equipment and adequate security answer different questions

Clinger–Cohen's information-technology definition excluded equipment a contractor acquires incidentally to a federal contract. That is a definition for the statute's IT-management framework, not a universal exemption for federal information placed on that equipment. The 1996 A-130 security appendix emphasized risk, management authorization, and controls for systems and major applications.

Sources and exact locations

- Clinger–Cohen Act in P.L. 104-106 — Division E, §5002(3), now 40 USC 11101(6). Read source

- A-130: Transmittal 3 — Appendix III, §§2–3. Read source
- A-130: Managing Information as a Strategic Resource — Appendix I §5(r). Read source

---

2000–2002

Law

Congress separates information duties from system duties

GISRA and the 2002 security legislation made agency-wide security programs central. The December 2002 FISMA text separately covered information collected or maintained by or on behalf of an agency and systems used or operated by an agency, its contractors, or other organizations on its behalf. It also covered support furnished by another agency, contractor, or other source. Those clauses are broader than a test of machine ownership.

Sources and exact locations

- GISRA in P.L. 106-398 — §1061, former 44 USC 3534. Read source
- Homeland Security Act of 2002, Title X — §1001, former 44 USC 3534. Read source
- E-Government Act / FISMA 2002 — Title III §301, former 44 USC 3544(a)–(b). Read source

---

2004–2011

OMB policy

Cloud use is treated as outsourced work, not a new escape from security

FIPS 199 and 200 supplied categorization and minimum-security standards. In its FY 2010 instructions, OMB included fully and partly outsourced services, including SaaS. Its example of incidental equipment was a contractor's corporate HR or finance system that neither used agency information nor interconnected with an agency system. The 2011 FedRAMP memorandum introduced a reusable cloud assessment and authorization process.

Sources and exact locations

- FIPS 199: Security Categorization — §§2–3. Read source
- FIPS 200: Minimum Security Requirements — §§2–3. Read source
- M-10-15, FY 2010 Reporting Instructions for the Federal Information Security Management Act and Agency Privacy Management — Questions 36–38, printed pp. 13–15; PDF pp. 17–19. Read source
- Security Authorization of Information Systems in Cloud Computing Environments — Scope and agency responsibilities. Read source

---

2014

Law

FISMA preserves both limbs of the duty

The Federal Information Security Modernization Act reorganized federal security responsibilities while preserving the distinct information and system clauses. They now appear in 44 USC 3554(a)(1)(A)(i) and (ii). Section 3554(b) still requires a program for information and systems supporting agency operations and assets, including support provided or managed by outside sources.

Sources and exact locations

- Federal Information Security Modernization Act — §2, 44 USC 3554. Read source
- 44 USC 3554 — Federal agency responsibilities — 44 USC 3554(a)–(b). Read source

---

2015–2016

Public comments

The A-130 revision draws concerns about private services

OMB sought public comments in October 2015. EPIC's December submission raised privacy concerns about private social-media and cloud services receiving visitor data through government websites. That concern illustrates why agency duties and private data practices cannot simply be assumed identical. It is a commenter's position, not an adopted tenant-only exception. The 2016 availability notice announces the revised circular; it is not a complete response-by-response account of the public comments.

Sources and exact locations

- Request for Comments on Circular No. A-130, Managing Information as a Strategic Resource — 80 FR 64022, October 22, 2015. Read source
- Comments of the Electronic Privacy Information Center to OMB on Circular No. A-130 — §III, pp. 5–6. Read source
- A-130 2016 final notice — 81 FR 49689, July 28, 2016. Read source

---

2016

OMB policy

A-130 expressly includes fully and partly provided cloud services

Appendix I's discussion of FISMA applicability quotes the information and system duties and includes agency-hosted, outsourced, and cloud-based solutions. It also explains that agencies remain accountable when federal information is used in incidentally acquired contractor equipment. Section 4(j) directs agencies to address relevant nonfederal entities through contracts and other agreements, oversight, assessment, inventories, and incident procedures.

Sources and exact locations

- A-130: Managing Information as a Strategic Resource — Appendix I §4(j); §5(r), printed pp. 25–26 / PDF pp. 62–63. Read source

---

2016

Regulation

NARA draws an explicit outsourcing–incidental distinction

The CUI final rule defines acting on behalf and distinguishes outsourced information processing from receiving federal information only incidentally to a different product or service. It expressly includes systems serving both government and private users in the federal-system branch. Its nonfederal branch prohibits treating such systems as agency systems and directs use of SP 800-171 for CUI confidentiality, subject to stated exceptions.

Sources and exact locations

- NARA CUI final rule and comment responses — 81 FR 63330–63331, responses; §§2002.4(hh), 2002.14(h); effective November 14, 2016. Read source
- 32 CFR Part 2002: Controlled Unclassified Information (2025 edition) — 32 CFR 2002.4(hh), 2002.14(h). Read source

---

2017–2023

Public comments

The boundary remains contested in acquisition rules

RAND asked DHS to adopt NARA's definition and distinguish incidental CUI handling from operating federal systems. In 2023, DHS said its rule did not federalize systems not operated for government, and separated its system-authorization requirements from broader CUI handling and incident duties. But DHS declined to adopt NARA's definition as the general FISMA definition, arguing that OMB should resolve that wider question. This is an express disagreement about the reach of a definition, not proof that either agency silently adopted the other's view.

Sources and exact locations

- RAND comments on DHS safeguarding proposal — Comments 1–4, pp. 3–9. Read source
- DHS safeguarding final rule and comment responses — 88 FR 40563–40565; §II.B.7, Definitions, 40571; basic clause and Alternate I; effective July 21, 2023. Read source

---

2018–2026

NIST guidance

NIST develops a way to manage separate boundaries and shared controls

SP 800-37 Revision 2 describes external providers beyond direct agency control, separate authorizations, and inherited safeguards. SP 800-47 Revision 1 follows information before, during, and after exchanges. SP 800-171 Revision 3 addresses CUI in nonfederal systems and explicitly separates that work from information and systems handled on behalf of an agency. SP 800-18 Revision 2, published June 2026, makes external services, information flows, and control responsibilities part of system planning.

Sources and exact locations

- SP 800-37 Rev. 2: Security and Privacy RMF — §2.5; Appendix G. Read source
- NIST SP 800-47 Revision 1 — §§1–3. Read source
- SP 800-171 Rev. 3: Protecting CUI — §1.1. Read source
- NIST SP 800-18 Revision 2 — §3.2. Read source

2022–2026

Law and OMB policy

FedRAMP's scope is its own question

Congress established FedRAMP in law in 2022 and assigned OMB the task of specifying covered categories. M-24-15 replaced the 2011 memorandum in 2024. It covers certain cloud services handling information for agencies while listing exclusions. The retrieved 2026 program guidance further emphasizes agency use cases. A single-agency application may be outside this shared program while the cloud infrastructure beneath it remains within scope. Neither result ends the agency's FISMA responsibilities.

Sources and exact locations

- FedRAMP Authorization Act in P.L. 117-263 — §5921. Read source
- 44 USC 3614 — Roles and responsibilities of the Office of Management and Budget — 44 USC 3614(1)(A). Read source
- Modernizing the Federal Risk and Authorization Management Program (FedRAMP) — §III. Read source
- FedRAMP scope guidance, retrieved October 24, 2026 — Agency Use Case Indicators; Single Agency Systems. Read source

---

Evidence library

Each source keeps its own edition and authority. The source links open local originals or complete extracted text. Original HTML snapshots may retain publisher assets; this report has no network dependencies.

Download sources (JSON) · Sources (CSV) · Claim-to-source index · Verified quotations

---

Law · 1974-12-31

Privacy Act, P.L. 93-579

Local original · Complete extracted text · Official / original publisher

Locations, provenance, and uses in this report

Historical edition

Retrieved 2026-10-10. SHA-256:
`e7ee29d2c9d09b077dc356a4583a4a008621dce40b0f23fd51e19b5368815d4a`

- Back to discussion — Privacy Act of 1974 §3, adding 5 USC 552a(m); 88 Stat. 1904 / PDF p. 9
- Back to discussion — §3, adding 5 USC 552a(m)

Law · 1980-12-11

Paperwork Reduction Act of 1980

Local original · Complete extracted text · Official / original publisher

Locations, provenance, and uses in this report

Historical edition

Retrieved 2026-10-10. SHA-256:
`5af687ae7085e87b72357c4ef3969bfa4388bddb179c76363ec7d49759036299`

- Back to discussion — 44 USC 3504–3506 as enacted

OMB circular · 1985-12-12

A-130: initial circular

Local original · Complete extracted text · Official / original publisher

Locations, provenance, and uses in this report

Amended by Transmittals 1–4.

Retrieved 2026-10-10. SHA-256:
`c6c996a0a79cfbae6c9220153a4d019871ee22bf0930fd180c70055cffe7b784`

- Back to discussion — §6; Appendix IV, analysis of §8b(2)–(3), 50 FR 52749; PDF p. 307

Law · 1988-01-08

Computer Security Act of 1987, P.L. 100-235

Local original · Complete extracted text · Official / original publisher

Locations, provenance, and uses in this report

Historical edition

Retrieved 2026-10-10. SHA-256:
`2eb2c0cdd6d2bbf652b358266e98be07fdb2b52526554aded1f90bb0a5238fd0`

- Back to discussion — §3, adding NBS Act §20(d)(2); §§5–7

OMB circular · 1993-06-25

A-130: Transmittal 1

Local original · Complete extracted text · Official / original publisher

Locations, provenance, and uses in this report

Historical amendment; later editions contain further changes.

Retrieved 2026-10-10. SHA-256:
`b394b7885e2a250a20af528c2c032bc8a749987bc7346c0f3bf385f00b05e270`

- Back to discussion — Appendix IV §3, analysis of §6: Government Information (1993)
- Back to discussion — Appendix IV, §3, Government Information

---

OMB circular · 1996-02-08

A-130: Transmittal 3

Local original · Complete extracted text · Official / original publisher

Locations, provenance, and uses in this report

Historical consolidated text; amended in 2000 and replaced in 2016.

Retrieved 2026-10-10. SHA-256:
`906a73bd9b77740b0ed2bfc6f2201ec33363e2a04def3f3108fc7aecc146c4b6`

- Back to discussion — Appendix IV, Government Information
- Back to discussion — Appendix IV, Government Information
- Back to discussion — Appendix III, §§2–3

Law · 1996-02-10

Clinger–Cohen Act in P.L. 104-106

Local original · Complete extracted text · Official / original publisher

Locations, provenance, and uses in this report

Historical edition

Retrieved 2026-10-10. SHA-256:
`60ecc3db67b9a71474f8e11cb310d1d86f8246fc9df154b31f93801dbe786c7e`

- Back to discussion — Division E §5002(3), now 40 USC 11101(6)
- Back to discussion — Division E, §5002(3), now 40 USC 11101(6)

Law · 2000-10-30

GISRA in P.L. 106-398

Local original · Complete extracted text · Official / original publisher

Locations, provenance, and uses in this report

Historical edition

Retrieved 2026-10-10. SHA-256:
`931a74e24e0288af43250e5e5d32c5c456c119904c08a6da4d87cb2adc0e41f8`

- Back to discussion — §1061, former 44 USC 3534

OMB circular · 2000-11-28

A-130 (2000), Appendix IV

Local original · Complete extracted text · Official / original publisher

Locations, provenance, and uses in this report

Historical edition

Retrieved 2026-10-10. SHA-256:
`dec37813f1c79ee93e2cf259690af4243f274a6f4643bcdbe6b283d3692a5ca3`

- Back to discussion — §3, Government Information
- Back to discussion — §3, Government Information

Law · 2002-11-25

Homeland Security Act of 2002, Title X

Local original · Official / original publisher

Locations, provenance, and uses in this report

General effective date 60 days after enactment; compare the December 17 E-Government Act separately.

Retrieved 2026-10-10. SHA-256:
`e96e8b44905469d308187a78a906db5695ebb0b3c218575e55835c62526a0fd2`

- Back to discussion — §1001, former 44 USC 3534

Law · 2002-12-17

E-Government Act / FISMA 2002

Local original · Complete extracted text · Official / original publisher

Locations, provenance, and uses in this report

Historical edition

Retrieved 2026-10-10. SHA-256:
`1eec72dc1f004c04be63c78eb850321592881cbf10bca889301f109dc5c9650e`

- Back to discussion — Title III §301, former 44 USC 3544(a)–(b)

Mandatory standard · 2004-02-01

FIPS 199: Security Categorization

Local original · Complete extracted text · Official / original publisher

Locations, provenance, and uses in this report

Historical edition

Retrieved 2026-10-10. SHA-256:
`73d19f05f71e30f378050f178aa3943c38790bbae56c07f2b5708c5a1a90242f`

- Back to discussion — §§2–3
- Back to discussion — §3
- Back to discussion — §§2–3

Mandatory standard · 2006-03-09

FIPS 200: Minimum Security Requirements

Local original · Complete extracted text · Official / original publisher

Locations, provenance, and uses in this report

Historical edition Publication date in this report checked against NIST publication history or the FIPS announcement; original bytes unchanged.

Retrieved 2026-10-10. SHA-256:
`107a9b9cdc8eccf37386aec28bbaf2dfaef5cfece17151ceabc3960423243a57`

- Back to discussion — FIPS 200, announcement §8, printed p. v / PDF p. 5
- Back to discussion — Announcement §§6, 8; standard §4
- Back to discussion — §§2–3
- Back to discussion — §§2–3

OMB memorandum · 2010-04-21

M-10-15, FY 2010 Reporting Instructions for the Federal Information Security Management Act and Agency Privacy Management

Local original · Complete extracted text · Official / original publisher

Locations, provenance, and uses in this report

Current applicability not assessed

Retrieved 2026-10-10. SHA-256:
`de73191abda2c3037a37d6ff60566a6dd72c9aacbeaa8f5337b1f7be467273d2`

- Back to discussion — Question 38, printed pp. 14–15
- Back to discussion — Questions 36–38, printed pp. 13–15; PDF pp. 17–19

Guidance · 2010-09-08

NARA Bulletin 2010-05: Guidance on Managing Records in Cloud Computing Environments

Local original · Complete extracted text · Official / original publisher

Locations, provenance, and uses in this report

Preserved official source; extraction is a reading aid, not a replacement for the original.

Retrieved 2026-10-24. SHA-256:
`c617280c8662418efa5fc3aeb4ac57e31edf64e062ce8eec016bf361875be094`

- Back to discussion — Questions 6–8
- Back to discussion — NARA Bulletin 2010-05, question 6 (September 8, 2010)
- Back to discussion — Questions 6–8
- Back to discussion — NARA Bulletin 2010-05, questions 6–8
- Back to discussion — Questions 6–8

NIST guidance · 2011-09-01

SP 800-145: The NIST Definition of Cloud Computing

Local original · Complete extracted text · Official / original publisher

Locations, provenance, and uses in this report

Historical edition

Retrieved 2026-10-10. SHA-256:
`7b0c1a9fdfc67218b8ba2098f448c100c27070db91736b3c87fed63bfa21d418`

- Back to discussion — §2, IaaS definition

Unnumbered memorandum · 2011-12-08

Security Authorization of Information Systems in Cloud Computing Environments

Local original · Complete extracted text · Official / original publisher

Locations, provenance, and uses in this report

Rescinded by M-24-15 (opening and concluding sections).

Retrieved 2026-10-10. SHA-256:
`1000dc126873b7d4831512434a5087d6991e7b02f73200a39d49e683ec068fbc`

- Back to discussion — Scope and agency responsibilities

Law · 2014-12-18

Federal Information Security Modernization Act

Local original · Complete extracted text · Official / original publisher

Locations, provenance, and uses in this report

Historical edition

Retrieved 2026-10-10. SHA-256:
`96ab24c78d410963ebb0bcd519dbe4b95ee800400c49ea4448e6d3f39c3eb917`

- Back to discussion — 44 USC 3554(a)(1)(A), shared introductory duty; 128 Stat. 3078
- Back to discussion — §2, enacting 44 USC 3554(a)(1)(A)(i); 128 Stat. 3078
- Back to discussion — §2, enacting 44 USC 3554(a)(1)(A)(ii); 128 Stat. 3078
- Back to discussion — 44 USC 3554(a)(1)(B); 128 Stat. 3078
- Back to discussion — 44 USC 3554(a)(2)(D); 128 Stat. 3078
- Back to discussion — 44 USC 3554(b); 128 Stat. 3079
- Back to discussion — §2, 44 USC 3554(a)(1)(A)(ii)
- Back to discussion — §2, 44 USC 3554

Notice · 2015-10-22

Request for Comments on Circular No. A-130, Managing Information as a Strategic Resource

Local original · Complete extracted text · Official / original publisher

Locations, provenance, and uses in this report

Official issuing or archival host

Retrieved 2026-10-23. SHA-256:
`60ad864505a08346fbe8ce1da82c748210a4f0ba61a64da2f46501cee090b588`

- Back to discussion — 80 FR 64022, October 22, 2015

Public comment · 2015-12-04

Comments of the Electronic Privacy Information Center to OMB on Circular No. A-130

Local original · Complete extracted text · Official / original publisher

Locations, provenance, and uses in this report

Primary commenter-hosted submission

Retrieved 2026-10-23. SHA-256:
`3b51b3a36fd035b9d923adc163b73c043961d022bc85700e9406ce26a02da114`

- Back to discussion — §III, pp. 5–6

OMB circular · 2016-07-28

A-130: Managing Information as a Strategic Resource

Local original · Complete extracted text · Official / original publisher

Locations, provenance, and uses in this report

2016 revision; later laws and memoranda also apply.

Retrieved 2026-10-10. SHA-256:
`f1a2e73a1063eab7d83da2a3bfa810f3aaebc9a6ef8e9d264ffc57ccd02152e6`

- Back to discussion — §10(22)–(23)
- Back to discussion — Appendix I §4(d)(1), printed p. 7 / PDF p. 44
- Back to discussion — Appendix I §4(d)(1)–(8)
- Back to discussion — Appendix I §4(j)(1)–(2)
- Back to discussion — §10(23); Appendix I §5(r)
- Back to discussion — Appendix I §4(j)(1), printed p. 14 / PDF p. 51
- Back to discussion — Appendix I §4(j)(2), printed p. 14 / PDF p. 51

- Back to discussion — Appendix I §4(j)(2)(a), printed p. 14 / PDF p. 51
- Back to discussion — Appendix I §4(j)(2)(b), printed p. 14 / PDF p. 51
- Back to discussion — Appendix I §4(j)(2)(c), printed p. 14 / PDF p. 51
- Back to discussion — Appendix I §4(j)(2)(d), printed p. 14 / PDF p. 51
- Back to discussion — Appendix I §4(j)(2)(f), printed p. 14 / PDF p. 51
- Back to discussion — Appendix I §4(j)(2)(e), printed p. 14 / PDF p. 51
- Back to discussion — Appendix I §5(r), printed p. 26 / PDF p. 63
- Back to discussion — Appendix I §5(r), pp. 25–26
- Back to discussion — Appendix I §4(j)(2)(b)
- Back to discussion — Appendix I §4(j)(2)(c)–(f)
- Back to discussion — Appendix I §4(j)(2)(e)
- Back to discussion — Appendix I §5(r), printed p. 25 / PDF p. 62
- Back to discussion — Appendix I §4(j), §5(r)
- Back to discussion — §5; Appendix II
- Back to discussion — Appendix I §4(j)
- Back to discussion — Appendix I §5(r)
- Back to discussion — Appendix I §4(j); §5(r), printed pp. 25–26 / PDF pp. 62–63

OMB circular · 2016-07-28

A-130 2016 final notice

Local original · Complete extracted text · Official / original publisher

Locations, provenance, and uses in this report

Historical edition

Retrieved 2026-10-10. SHA-256:
`d7d35c2d1635f604b9e68594a710258ff21568c8477c0fb627744e36bd358939`

- Back to discussion — 81 FR 49689, July 28, 2016

Regulation · 2016-09-14

NARA CUI final rule and comment responses

Local original · Complete extracted text · Official / original publisher

Locations, provenance, and uses in this report

Preserved official source; extraction is a reading aid, not a replacement for the original.

Retrieved 2026-10-24. SHA-256:
`f3e00594bf25f429b30f881900f3bec0fff2b70001d0b152902eb4b58fdc0a4f`

- Back to discussion — 81 FR 63330–63331, responses; §§2002.4(hh), 2002.14(h); effective November 14, 2016

Public comment · 2017-03-23

RAND comments on DHS safeguarding proposal

Local original · Complete extracted text · Official / original publisher

Locations, provenance, and uses in this report

Original acquired by inforegs from Regulations.gov; SHA-256 verified. Direct retrieval October 24 returned 403.

Retrieved 2026-10-23. SHA-256:
`b94bb7c8a4cfc506c67606cded3fb6ee7dca00598268f06e5fb47c14ed17ee97`

- Back to discussion — Comments 1–4, pp. 3–9

NIST guidance · 2018-12-20

SP 800-37 Rev. 2: Security and Privacy RMF

Local original · Complete extracted text · Official / original publisher

Locations, provenance, and uses in this report

Historical edition Publication date in this report checked against NIST publication history or the FIPS announcement; original bytes unchanged.

Retrieved 2026-10-10. SHA-256:
`4f75e1136bb905a654f1bcd9eefefb4108f47597276ee5eec0688f6d96f6a01d`

- Back to discussion — Appendix D, System Owner, p. 123 / PDF p. 142
- Back to discussion — Appendix D, Authorizing Official, p. 114 / PDF p. 133
- Back to discussion — Appendix D, p. 114; Appendix G, pp. 159–160
- Back to discussion — Appendix D, Information Owner or Steward, p. 119 / PDF p. 138
- Back to discussion — §2.5, footnote 42, p. 17 / PDF p. 36
- Back to discussion — Appendix G, p. 159 / PDF p. 178

- Back to discussion — Appendix G, pp. 159–160
- Back to discussion — Appendix D, pp. 114, 119, 123; Appendix G
- Back to discussion — Appendix D, p. 114; Appendix G, p. 160
- Back to discussion — Appendix G
- Back to discussion — Appendix G, p. 159 / PDF p. 178
- Back to discussion — Appendix G, p. 160 / PDF p. 179
- Back to discussion — Appendix G, pp. 159–160
- Back to discussion — §2.4; Appendix G
- Back to discussion — Appendix G
- Back to discussion — Appendix G, pp. 159–161
- Back to discussion — Appendix G
- Back to discussion — §§2.4–2.5; Appendix G
- Back to discussion — §2.5; Appendix G

NIST guidance · 2020-09-01

SP 800-53 Rev. 5: Security and Privacy Controls

Local original · Complete extracted text · Official / original publisher

Locations, provenance, and uses in this report

Historical edition

Retrieved 2026-10-10. SHA-256:
`fc63bcd61715d0181dd8e85998b1e6201ae3515fc6626102101cab1841e11ec6`

- Back to discussion — SA-9; AC-20; CA-3
- Back to discussion — SA-9
- Back to discussion — SA-9; SC-28, Protection of Information at Rest
- Back to discussion — CA-3; SC-7; SC-8, Transmission Confidentiality and Integrity

---

NIST guidance · 2021-07-20

NIST SP 800-47 Revision 1

Local original · Complete extracted text · Official / original publisher

Locations, provenance, and uses in this report

Preserved official source; extraction is a reading aid, not a replacement for the original.

Retrieved 2026-10-24. SHA-256:
`3ba5248bab614da212440a1bcfe814f0068ef95ebc2d73025742bc78a89c865a`

- Back to discussion — §§2–3
- Back to discussion — §§2–3
- Back to discussion — §§1–3

Regulation · 2021-11

FAR 52.204-21, November 2021 clause; FAC 2026-01

Local original · Complete extracted text · Official / original publisher

Locations, provenance, and uses in this report

Preserved official source; extraction is a reading aid, not a replacement for the original.

Retrieved 2026-10-24. SHA-256:
`da2a7d9150526fabb12e1869ebd82592b7fdebb1e01dd8081d93d401d6e4534d`

- Back to discussion — FAR 52.204-21(a), definition; November 2021 clause, retrieved FAC 2026-01
- Back to discussion — FAR 52.204-21(b)(1)
- Back to discussion — FAR 52.204-21(a)–(c)
- Back to discussion — FAR 52.204-21(a)–(c)

Law · 2022-12-23

FedRAMP Authorization Act in P.L. 117-263

Local original · Complete extracted text · Official / original publisher

Locations, provenance, and uses in this report

Historical edition

Retrieved 2026-10-10. SHA-256:
`9e5d37dfa7d1282073c16f3dde21978078f62f58f9db36f4828e270e02de933f`

- Back to discussion — §5921

Regulation · 2023-06-21

DHS safeguarding final rule and comment responses

Local original · Complete extracted text · Official / original publisher

Locations, provenance, and uses in this report

Preserved official source; extraction is a reading aid, not a replacement for the original.

Retrieved 2026-10-24. SHA-256:
`a5b720fb0fd7297d3756086f4e979a98060d8f8cefb74866aec6bd403ebb9fd5`

- Back to discussion — §II.B.7, 88 FR 40571
- Back to discussion — 88 FR 40563–40565; §II.B.7, Definitions, 40571; basic clause and Alternate I; effective July 21, 2023

Law · 2024 Code edition

5 USC 552 — FOIA

Local original · Complete extracted text · Official / original publisher

Locations, provenance, and uses in this report

Preserved official source; extraction is a reading aid, not a replacement for the original.

Retrieved 2026-10-24. SHA-256:
`b1fad0a21337dc814f2f05e47f260dba90752af9f72c66c7b0323477183323de`

- Back to discussion — 5 USC 552(f)(2)(B)
- Back to discussion — 5 USC 552(f)(2)(B), 2024 Code edition
- Back to discussion — 5 USC 552(f)(2)(B)
- Back to discussion — 5 USC 552(f)(2)(B)

Law · 2024 Code edition

44 USC 3301 — Federal records

Local original · Complete extracted text · Official / original publisher

Locations, provenance, and uses in this report

Preserved official source; extraction is a reading aid, not a replacement for the original.

Retrieved 2026-10-24. SHA-256:
`ff9de8a95c4847cd61e115e1863f0a86fb766e66ffa29faae43bbb42623cb1ec`

- Back to discussion — 44 USC 3301
- Back to discussion — 44 USC 3301
- Back to discussion — 44 USC 3301

NIST guidance · 2024-05-14

SP 800-171 Rev. 3: Protecting CUI

Local original · Complete extracted text · Official / original publisher

Locations, provenance, and uses in this report

Historical edition Publication date in this report checked against NIST publication history or the FIPS announcement; original bytes unchanged.

Retrieved 2026-10-10. SHA-256:
`3e4631df8b5d61f40a6e542b52779ef30ddbbfff31e09214fa94ad6e6f5e6d08`

- Back to discussion — §1.1
- Back to discussion — §1.1 and footnote 8
- Back to discussion — §1.1, p. 2 / PDF p. 12; read with footnote 8
- Back to discussion — §1.1, p. 2 / PDF p. 12
- Back to discussion — §1.1, footnote 8; §2
- Back to discussion — §1.1
- Back to discussion — §1.1

OMB memorandum · 2024-07-25

Modernizing the Federal Risk and Authorization Management Program (FedRAMP)

Local original · Complete extracted text · Official / original publisher

Locations, provenance, and uses in this report

Current applicability not assessed

Retrieved 2026-10-10. SHA-256:
`07aabe7fd0baa34e3c77b7c9537204c6ac1caff473e04af8dc7e40743c30250a`

- Back to discussion — §IV, footnote 7
- Back to discussion — §§III–IV, footnote 7
- Back to discussion — §III, p. 5; exclusions follow this sentence

- Back to discussion — §IV, footnote 7, p. 6
- Back to discussion — §III exclusions
- Back to discussion — §III
- Back to discussion — §III
- Back to discussion — §III, exclusion 1
- Back to discussion — §III

Regulation · 2025

32 CFR Part 2002: Controlled Unclassified Information (2025 edition)

Local original · Complete extracted text · Official / original publisher

Locations, provenance, and uses in this report

official host

Retrieved 2026-10-23. SHA-256:
`7613256287fea6dadc38f7279cb2c63c377f808295e70fa9785660651236958a`

- Back to discussion — 32 CFR 2002.14(h)(1), 2025 annual edition
- Back to discussion — 32 CFR 2002.14(h)(1)–(2); 2002.2
- Back to discussion — 32 CFR 2002.14(h)(2), 2025 annual edition
- Back to discussion — 32 CFR 2002.14(h)(1)–(2); 2002.4(hh)
- Back to discussion — 32 CFR 2002.2(b)(5), 2002.14(h)(2)
- Back to discussion — 32 CFR 2002.14(h)
- Back to discussion — 32 CFR 2002.16, 2002.18
- Back to discussion — 32 CFR 2002.14(f)
- Back to discussion — 32 CFR 2002.14(h)
- Back to discussion — 32 CFR 2002.14(h)(2)
- Back to discussion — 32 CFR 2002.4(hh), 2002.14(h)

NIST guidance · 2026-06-30

NIST SP 800-18 Revision 2

Local original · Complete extracted text · Official / original publisher

Locations, provenance, and uses in this report

Preserved official source; extraction is a reading aid, not a replacement for the original.

Retrieved 2026-10-24. SHA-256:
`640f9124469f285fc39dbeffd59708c84043d1a6b64cc87988f31e7e98942371`

- Back to discussion — §3.2
- Back to discussion — §3.2, System Operational Status; SP 800-37 Task M-7
- Back to discussion — §3.2
- Back to discussion — §3.2

Publication status · 2026-10-24

NIST publication status: SP 800-18 Revision 2

Local original · Complete extracted text · Official / original publisher

Locations, provenance, and uses in this report

Retained from the earlier report for stable source links; not cited in this replacement.

Retrieved 2026-10-24. SHA-256:
`6e9b69244d8347df4a1b6c2a70ba411afbafd55c14ea748e420c6279501878a6`

Publication status · 2026-10-24

NIST publication status: SP 800-53 Revision 5 / Release 5.2.0

Local original · Complete extracted text · Official / original publisher

Locations, provenance, and uses in this report

Retained from the earlier report for stable source links; not cited in this replacement.

Retrieved 2026-10-24. SHA-256:
`00c4e550ba1326976657136497711dc3f4dffc86e90f0d71052a3ebdc1b4d21c`

Publication status · 2026-10-24

NIST publication status: SP 800-171 Revision 3

Local original · Complete extracted text · Official / original publisher

Locations, provenance, and uses in this report

Retained from the earlier report for stable source links; not cited in this replacement.

Retrieved 2026-10-24. SHA-256:
`a3cdded2f973b252b68e2082f794626a425c9bdbbf31ce7afb4a8ff1d90bf595`

Program guidance · Retrieved 2026-10-24

FedRAMP scope guidance, retrieved October 24, 2026

Local original · Complete extracted text · Official / original publisher

Locations, provenance, and uses in this report

Official FedRAMP/2026 repository, default branch snapshot. Retrieval date is not issuance date.

Retrieved 2026-10-24. SHA-256:
`a338ad564d8c1eb0a6929e79df24d864bb214e66e12e54a2ae708ef18a9e26f7`

- Back to discussion — Agency Use Case Indicators; Social Media & Communications; Single Agency Systems
- Back to discussion — Social Media & Communications; Agency Use Case Indicators
- Back to discussion — Single Agency Systems
- Back to discussion — Agency Use Case Indicators; Single Agency Systems

---

Law · Through 2026-09-30

44 USC 3554 — Federal agency responsibilities

Local original · Read formatted text · Official / original publisher

Locations, provenance, and uses in this report

OLRC release 119-118; unchanged existing collection. Later-law verification incomplete.

Retrieved 2026-10-10. SHA-256:
`7966161a532f2b1ddde650c8aaad3425737f85c578cac04fd4f0ce57ca97ead8`

- Back to discussion — 44 USC 3554(a)(1)(A)(i)–(ii); collected Code through September 30, 2026
- Back to discussion — 44 USC 3554(a)(2)(A)–(D), (b)(1)–(8)
- Back to discussion — 44 USC 3554(b)(7)
- Back to discussion — §3554(a)(1)(A), (b)
- Back to discussion — §3554(a)(2)(D), (b)(5)
- Back to discussion — §3554(b)(7)
- Back to discussion — 44 USC 3554(a)–(b)

- Back to discussion — 44 USC 3554(a)(1)(A)
- Back to discussion — 44 USC 3554(a)–(b)
- Back to discussion — 44 USC 3554(a)–(b)

Law · Through 2026-09-30

44 USC 3502 — Definitions

Local original · Read formatted text · Official / original publisher

Locations, provenance, and uses in this report

OLRC release 119-118; unchanged existing collection. Later-law verification incomplete.

Retrieved 2026-10-10. SHA-256:
`7966161a532f2b1ddde650c8aaad3425737f85c578cac04fd4f0ce57ca97ead8`

- Back to discussion — 44 USC 3502(8)

Law · Through 2026-09-30

44 USC 3506 — Federal agency responsibilities

Local original · Read formatted text · Official / original publisher

Locations, provenance, and uses in this report

OLRC release 119-118; unchanged existing collection. Later-law verification incomplete.

Retrieved 2026-10-10. SHA-256:
`7966161a532f2b1ddde650c8aaad3425737f85c578cac04fd4f0ce57ca97ead8`

- Back to discussion — 44 USC 3506(c)

Law · Through 2026-09-30

44 USC 3614 — Roles and responsibilities of the Office of Management and Budget

Local original · Read formatted text · Official / original publisher

Locations, provenance, and uses in this report

OLRC release 119-118; unchanged existing collection. Later-law verification incomplete.

Retrieved 2026-10-10. SHA-256:
`7966161a532f2b1ddde650c8aaad3425737f85c578cac04fd4f0ce57ca97ead8`

- Back to discussion — 44 USC 3614(1)(A)

Law · Through 2026-09-30

5 USC 552a — Records maintained on individuals

Local original · Read formatted text · Official / original publisher

Locations, provenance, and uses in this report

OLRC release 119-118; unchanged existing collection. Later-law verification incomplete.

Retrieved 2026-10-10. SHA-256:
`f8e6aa5def8854f8d2b1702eccd36962b92080d6212b64c543fa72f1ae1b209a`

- Back to discussion — 5 USC 552a(a)(5), (b), (e), (m)
- Back to discussion — 5 USC 552a(e), (m)
- Back to discussion — 5 USC 552a(b)
- Back to discussion — 5 USC 552a(m)

Coverage, source dates, and open questions

- This is a civilian, unclassified analysis. National security systems, classified information, DoD contracting, CMMC, sector-specific secrecy laws, and every agency supplement are not comprehensively analyzed.
- The report distinguishes issuance, effective dates, source editions, and retrieval dates. It does not reconstruct every intervening amendment or establish the original intent of Congress from policy documents written later.
- The law links use the site's OLRC release 119-118, through September 30, 2026. FOIA and records-definition additions use the 2024 Code. The CUI text is the 2025 annual CFR. October 24 attempts to retrieve current OLRC and eCFR text failed. These limits prevent a claim that every legal change through October 24 has been verified.
- NIST publication status and the official FedRAMP scope source were checked on October 24, 2026. The FedRAMP source is program guidance and must be read alongside M-24-15. Its examples do not amend

FISMA. The current-law discussion states the result supported by the identified editions, with the currency limits above.

- Selected public comments are preserved as comments. EPIC and RAND do not speak for the government. The complete 2015 A-130 comment docket and a provision-by-provision OMB response were not recovered in this research. No causal claim is made that a particular comment produced final wording.

- Inforegs supplied discovery and exact passage retrieval. Its semantic backfill was incomplete, so searches used lexical retrieval; results were not exhaustive. Original documents, surrounding provisions, and official publication pages were checked separately. A missing search hit is not evidence that no rule existed.

- Figma and AWS illustrate service models under stated assumptions. This report does not inspect their private agreements, actual system boundaries, or current certification status. It offers a source-based analysis, not an agency authorization or a vendor compliance verdict.

What still needs an agency-specific answer

The actual information, purpose of the service, applicable contract, agency policies, system architecture, provider access, and available assurance determine the result for a real purchase. Where authorities differ in scope, record the reason for the chosen interpretation instead of treating a convenient definition as universal.

Research and review were performed in this chat, including a separate self-review. No independent legal review or vendor assessment was performed. Research refreshes are manual.
